

SSH Key Abuse adalah kategori privilege escalation atau lateral movement yang muncul ketika kunci SSH dikelola dengan buruk.

Karena teknik ini dapat digunakan untuk mendapatkan akses ke sistem, saya tidak akan memberikan langkah eksploitasi operasional terhadap sistem nyata. Namun, saya bisa menjelaskan bagaimana mengenali dan menganalisis salah konfigurasi SSH dalam konteks audit keamanan atau CTF yang sah.

Apa itu SSH Key?

SSH menggunakan pasangan kunci:

Private Key (rahasia)

Public Key (boleh dibagikan)

Contoh:

```
id_rsa          ← private key
id_rsa.pub      ← public key
```

Jika sebuah akun mempercayai public key tertentu, pemilik private key yang cocok dapat melakukan autentikasi.

Lokasi yang Harus Diperiksa

Saat melakukan enumerasi pada mesin Linux:

```
ls -la ~/.ssh
```

atau

```
ls -la /home/*/.ssh
```

File penting:

```
authorized_keys
id_rsa
id_ed25519
known_hosts
config
```

1. Private Key Tersimpan di Tempat yang Salah

Temuan yang sering muncul:

```
/home/dev/id_rsa
/var/www/html/id_rsa
/backup/id_rsa
```

Jika private key dapat dibaca oleh user yang tidak seharusnya, itu merupakan temuan keamanan serius.

Mitigasi:

- Simpan private key hanya di direktori pemilik.
- Permission 600.
- Jangan menyimpan private key di webroot.

2. Permission Terlalu Longgar

Periksa:

`ls -la ~/.ssh`

Contoh buruk:

`-rw-rw-rw- id_rsa`

atau

`drwxrwxrwx .ssh`

Mitigasi:

<code>~/.ssh</code>	→ 700
<code>id_rsa</code>	→ 600
<code>authorized_keys</code>	→ 600

3. Reuse Key Antar User

Contoh:

`/home/john/.ssh`
`/home/alice/.ssh`

Kedua user menggunakan pasangan key yang sama.

Risiko:

Kompromi satu akun

↓

Kompromi akun lain

Mitigasi:

Setiap user memiliki key unik.

4. Authorized Keys yang Tidak Dikenal

Periksa:

`cat ~/.ssh/authorized_keys`

Cari:

ssh-rsa AAAA...

Pertanyaan:

Milik siapa?

Masih diperlukan?

Kapan ditambahkan?

Dalam audit keamanan, key yang tidak dikenal harus dianggap mencurigakan.

5. Backup Berisi SSH Key

Temuan umum di CTF:

backup.zip
backup.tar.gz
home_backup.tar

Setelah dianalisis:

/home/user/.ssh/

berisi key.

Ini menunjukkan proses backup tidak menyaring informasi sensitif.

Mitigasi:

Jangan menyertakan private key dalam backup umum.
Enkripsi backup sensitif.

6. Key di Source Code atau Git Repository

Cari:

```
find / -name ".git" 2>/dev/null
```

atau

```
grep -R "BEGIN OPENSSSH PRIVATE KEY" .
```

Kadang developer tidak sengaja meng-commit private key.

Mitigasi:

Gunakan secret scanning.
Rotasi key yang bocor.

7. SSH Config yang Berisiko

Periksa:

```
cat ~/.ssh/config
```

Cari:

```
Host *  
IdentityFile ...
```

atau konfigurasi yang terlalu permisif.

Checklist SSH Enumeration

Saat mendapat shell pada mesin CTF/lab:

```
whoami  
ls -la ~/.ssh  
cat ~/.ssh/authorized_keys  
find / -name id_rsa 2>/dev/null  
find / -name "*.pem" 2>/dev/null  
find / -name "*.key" 2>/dev/null  
find / -name authorized_keys 2>/dev/null
```

Indikator SSH Misconfiguration

Perhatikan:

- ✓ Private key dapat dibaca user lain
- ✓ authorized_keys tidak terkontrol
- ✓ Backup berisi key
- ✓ Repository berisi key
- ✓ Permission terlalu longgar
- ✓ Key digunakan banyak akun
- ✓ Akun lama masih memiliki key aktif

Cara Menulis Temuan di Laporan

Temuan: SSH private key tersimpan dalam lokasi yang dapat diakses oleh pihak yang tidak berwenang.

Dampak: Risiko akses tidak sah ke akun yang mempercayai key tersebut.

Mitigasi:

Rotasi key yang terpapar.

Terapkan permission yang benar.

Audit authorized_keys.

Gunakan key unik per pengguna.

Hapus key yang tidak lagi digunakan.

Setelah SSH Key Abuse, topik privilege escalation yang paling sering muncul di Boot2Root adalah Linux Capabilities, yang sering lebih sulit dikenali daripada SUID dan Cron tetapi sangat umum pada mesin tingkat menengah hingga sulit.